GCP INFRASTRUCTURE ASSURANCE

Compliance and Least-Privilege Report

A deterministic, read-only assessment of project IAM, service-account credentials, and Cloud Storage security controls.

ASSESSMENT STATUS	ACTION REQUIRED

6	5	3	1	1
RESOURCES	VIOLATIONS	CRITICAL	HIGH	MEDIUM

Project	example-production
Source	offline
Generated	2026-08-22T10:03:31.874666Z
Ruleset	GCP Least-Privilege and Storage Baseline 1.0.0
Schema version	1.0

Important: this report is evidence from the supplied snapshot or the APIs successfully queried at scan time. It is not a certification, and framework mappings should be validated against the version adopted by your organization.

Executive finding register

Severity	Finding	Resource	Rule
CRITICAL	Privileged primitive role assigned to service account	batch-runner@example-production.iam.gserviceaccount.com	IAM_PRIVILEGED_SERVICE_ACCOUNT
CRITICAL	Privileged primitive role assigned to service account	legacy-worker@example-production.iam.gserviceaccount.com	IAM_PRIVILEGED_SERVICE_ACCOUNT
CRITICAL	Publicly accessible Cloud Storage bucket	example-public-data	STORAGE_PUBLIC_ACCESS
HIGH	Uniform bucket-level access is disabled	example-public-data	STORAGE_UNIFORM_ACCESS_DISABLED
MEDIUM	Service account key exceeds rotation age	projects/example-production/serviceAccounts/legacy-worker@example-production.iam.gserviceaccount.com/keys/example-user-key-1	IAM_STALE_SERVICE_ACCOUNT_KEY

Scan coverage

Projects	1
IAM bindings	4
Service accounts	2
Service-account keys	1
Cloud Storage buckets	2
Checks evaluated	13

Detailed findings

1. Privileged primitive role assigned to service account

CRITICAL	**Rule:** IAM_PRIVILEGED_SERVICE_ACCOUNT **Finding ID:** FND-A43E7A961C7E66D5

Resource: service_account / batch-runner@example-production.iam.gserviceaccount.com

Principal: serviceAccount:batch-runner@example-production.iam.gserviceaccount.com

Service account batch-runner@example-production.iam.gserviceaccount.com has roles/editor, which violates the configured least-privilege policy.

Evidence: `{"assigned_role": "roles/editor", "conditional": false, "conditions": [], "disallowed_roles": ["roles/editor", "roles/owner"], "role": "roles/editor"}`

Recommended action: Remove the primitive Owner/Editor grant and replace it with the smallest predefined or custom role required by the workload.

Framework mapping: CIS Google Cloud Platform Foundations Benchmark v3.0 1.5 - Ensure service accounts do not have administrative privileges; NIST SP 800-53 Rev. 5 AC-6 - Least Privilege; NIST SP 800-53 Rev. 5 AC-6(5) - Privileged Accounts

2. Privileged primitive role assigned to service account

CRITICAL	**Rule:** IAM_PRIVILEGED_SERVICE_ACCOUNT **Finding ID:** FND-ED52080FE48BF4CE

Resource: service_account / legacy-worker@example-production.iam.gserviceaccount.com

Principal: serviceAccount:legacy-worker@example-production.iam.gserviceaccount.com

Service account legacy-worker@example-production.iam.gserviceaccount.com has roles/owner, which violates the configured least-privilege policy.

Evidence: `{"assigned_role": "roles/owner", "conditional": false, "conditions": [], "disallowed_roles": ["roles/editor", "roles/owner"], "role": "roles/owner"}`

Recommended action: Remove the primitive Owner/Editor grant and replace it with the smallest predefined or custom role required by the workload.

Framework mapping: CIS Google Cloud Platform Foundations Benchmark v3.0 1.5 - Ensure service accounts do not have administrative privileges; NIST SP 800-53 Rev. 5 AC-6 - Least Privilege; NIST SP 800-53 Rev. 5 AC-6(5) - Privileged Accounts

3. Publicly accessible Cloud Storage bucket

CRITICAL	**Rule:** STORAGE_PUBLIC_ACCESS **Finding ID:** FND-40FE7624488CC627

Resource: storage_bucket / example-public-data

Principal: allUsers

Bucket example-public-data grants access to public principal(s): allUsers.

Evidence: `{"public_access_prevention": "inherited", "public_grants": [{"principal": "allUsers", "role": "READER", "source": "bucket_acl"}, {"principal": "allUsers", "role": "roles/storage.objectViewer", "source": "iam_policy"}]}`

Recommended action: Remove public principals from IAM and ACLs, enable Public Access Prevention, and grant access only to named principals.

Framework mapping: CIS Google Cloud Platform Foundations Benchmark v3.0 5.1 - Ensure Cloud Storage buckets are not anonymously or publicly accessible; NIST SP 800-53 Rev. 5 AC-3 - Access Enforcement; NIST SP 800-53 Rev. 5 AC-5 - Separation of Duties; NIST SP 800-53 Rev. 5 AC-6 - Least Privilege; NIST SP 800-53 Rev. 5 MP-2 - Media Access

4. Uniform bucket-level access is disabled

HIGH	**Rule:** STORAGE_UNIFORM_ACCESS_DISABLED **Finding ID:** FND-04DF5879FA2A5EBA

Resource: storage_bucket / example-public-data

Principal: Not applicable

Bucket example-public-data permits legacy object/bucket ACL behavior because uniform bucket-level access is disabled.

Evidence: `{"public_access_prevention": "inherited", "uniform_bucket_level_access": false}`

Recommended action: Migrate required ACL grants to bucket IAM and enable uniform bucket-level access.

Framework mapping: CIS Google Cloud Platform Foundations Benchmark v3.0 5.2 - Ensure uniform bucket-level access is enabled; NIST SP 800-53 Rev. 5 AC-3 - Access Enforcement; NIST SP 800-53 Rev. 5 AC-5 - Separation of Duties; NIST SP 800-53 Rev. 5 AC-6 - Least Privilege; NIST SP 800-53 Rev. 5 MP-2 - Media Access

5. Service account key exceeds rotation age

MEDIUM	**Rule:** IAM_STALE_SERVICE_ACCOUNT_KEY **Finding ID:** FND-47160AABC564AA90

Resource: service_account_key / projects/example-production/serviceAccounts/legacy-worker@example-production.iam.gserviceaccount.com/keys/example-user-key-1

Principal: serviceAccount:legacy-worker@example-production.iam.gserviceaccount.com

Key projects/example-production/serviceAccounts/legacy-worker@example-production.iam.gserviceaccount.com/keys/example-user-key-1 is 233.42 days old; the configured maximum is 90 days.

Evidence: `{"age_days": 233.42, "disabled": false, "evaluated_at": "2026-08-22T10:03:31.874666Z", "key_origin": null, "key_type": "USER_MANAGED", "maximum_age_days": 90, "service_account": "legacy-worker@example-production.iam.gserviceaccount.com", "valid_after_time": "2026-01-01T00:00:00Z", "valid_before_time": "9999-12-31T23:59:59Z"}`

Recommended action: Replace and delete the old user-managed key. Prefer attached service accounts or Workload Identity Federation to avoid long-lived keys.

Framework mapping: CIS Google Cloud Platform Foundations Benchmark v3.0 1.7 - Rotate user-managed service account keys every 90 days or less; NIST SP 800-53 Rev. 5 IA-5 - Authenticator Management

Methodology and interpretation

IAM least privilege

Project bindings are inverted into principal-to-role assignments. Configured basic roles and assignment thresholds are evaluated, with explicit exemptions limited to the approved administrator allowlist.

Service-account key age

Only user-managed keys are subject to the rotation-age threshold. Google-managed keys are excluded because customers do not rotate them.

Public storage access

Bucket IAM policies and available legacy ACL entries are checked for allUsers and allAuthenticatedUsers. Uniform bucket-level access and public access prevention are recorded as independent defense-in-depth controls.

Encryption policy

Cloud Storage encrypts data at rest by default. A missing default KMS key is reported only when the local rules require customer-managed encryption keys; it must not be interpreted as plaintext storage.

Severity

CRITICAL indicates immediately exploitable or broad privilege exposure; HIGH indicates a material control failure; MEDIUM indicates security hygiene or rotation debt requiring planned remediation.

Report limitations

The scanner is read-only and does not remediate findings. Conditional IAM expressions are reported as evidence but are not formally proven for every possible request context. Organization, folder, inherited policies, object-level ACLs, KMS key state, VPC Service Controls, audit logging, and services outside the configured collectors are not implied to be compliant unless explicitly scanned.